POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Diretriz corporativa para operações diárias e proteção de dados

Empresa	2trac Tecnologia LTDA
Versão	1.1
Data de emissão	15/08/2026
Próxima revisão programada	Até 15/08/2027, ou antes em caso de mudança relevante, incidente ou requisito de parceiro
Classificação	Uso corporativo e compartilhamento controlado com parceiros

Documento-base para estabelecer controles mínimos de segurança da informação nas operações diárias da 2trac, sujeito à aprovação interna e revisão periódica.

1. Objetivo

Esta Política de Segurança da Informação estabelece princípios, responsabilidades e controles mínimos para proteger informações, sistemas, aplicações, credenciais, dados de clientes, parceiros, vendedores e demais ativos sob responsabilidade da 2trac Tecnologia LTDA.

A política deve orientar as operações diárias e apoiar a prevenção, detecção, resposta e recuperação de incidentes de segurança, garantindo que as medidas de proteção sejam aplicadas de forma consistente em toda a organização.

2. Escopo

Esta política aplica-se a:

- Sócios, administradores, empregados, estagiários, prestadores de serviço e terceiros com acesso a ativos da 2trac.
- Sistemas web, aplicativos, APIs, integrações, bancos de dados, ambientes em nuvem, redes, endpoints e repositórios de código.
- Dados próprios, de clientes, vendedores, parceiros, usuários finais e fornecedores.
- Atividades de desenvolvimento, suporte, operação, monitoramento, integração, atendimento e administração.

3. Princípios de segurança

- Confidencialidade: acesso às informações somente por pessoas e sistemas autorizados.
- Integridade: proteção contra alteração, destruição ou manipulação indevida.
- Disponibilidade: manutenção do acesso aos serviços e dados conforme a necessidade do negócio.
- Menor privilégio: concessão apenas dos acessos necessários para cada função.
- Segregação de funções: separação de atividades críticas sempre que aplicável.
- Rastreabilidade: registro de ações relevantes para investigação e auditoria.
- Privacidade por padrão: coleta e tratamento de dados limitados ao necessário para a finalidade legítima.
- Defesa em profundidade: uso de múltiplas camadas complementares de segurança.

4. Governança e responsabilidades

4.1 Direção

- Aprovar esta política e garantir recursos compatíveis com os riscos identificados.
- Designar responsáveis por segurança, tecnologia, privacidade e continuidade, de acordo com a estrutura da empresa.

4.2 Responsável por Segurança da Informação

- Manter e revisar esta política e seus procedimentos associados.
- Coordenar gestão de riscos, vulnerabilidades, incidentes e controles de acesso.
- Promover conscientização e acompanhar evidências de conformidade.

4.3 Colaboradores e terceiros

- Cumprir esta política, proteger credenciais e reportar imediatamente eventos suspeitos.
- Utilizar recursos corporativos somente para finalidades autorizadas.
- Não compartilhar dados, arquivos, segredos, chaves, tokens ou senhas sem autorização.

5. Classificação e tratamento da informação

Classificação	Exemplos	Proteção mínima	Compartilhamento
Pública	Materiais institucionais aprovados	Integridade e controle de publicação	Livre após aprovação
Interna	Procedimentos, rotinas, documentação interna	Acesso autenticado	Somente pessoal autorizado
Confidencial	Dados de clientes, contratos, dados comerciais	Acesso restrito, criptografia quando aplicável, logs	Necessidade de negócio e autorização
Restrita	Senhas, tokens, chaves, segredos, backups sensíveis	Cofre de segredos, acesso mínimo, MFA, monitoramento	Não compartilhar fora dos meios autorizados

6. Controle de acesso e identidade

- Toda conta deve ser individual, identificável e vinculada a uma pessoa ou serviço responsável.
- Autenticação multifator deve ser habilitada em sistemas críticos, painéis administrativos, nuvem, repositórios de código e serviços que a suportem.
- Acessos devem seguir o princípio do menor privilégio e ser revistos periodicamente.
- Contas de ex-colaboradores, terceiros ou usuários sem necessidade de acesso devem ser desativadas imediatamente.
- Credenciais privilegiadas e segredos devem ser armazenados em gerenciador/cofre apropriado; é proibido manter segredos em código-fonte, chats, e-mails ou arquivos não protegidos.
- Senhas devem ser únicas, fortes e não reutilizadas entre serviços corporativos.

7. Segurança de dispositivos e estações de trabalho

- Sistemas operacionais, navegadores, ferramentas e agentes de segurança devem ser mantidos atualizados.
- Dispositivos corporativos devem utilizar bloqueio automático, senha ou biometria e criptografia de armazenamento quando suportada.
- Software não autorizado ou de procedência duvidosa não deve ser instalado.
- Antivírus/antimalware e mecanismos equivalentes devem estar ativos quando aplicáveis.
- É proibido desabilitar controles de segurança sem autorização e registro da exceção.
- Perda, furto ou comprometimento de dispositivo deve ser reportado imediatamente.

8. Redes, comunicação e acesso remoto

- Acesso administrativo remoto deve utilizar canais protegidos e protocolos seguros.
- Serviços expostos à Internet devem ser limitados ao necessário e protegidos por autenticação, filtragem e monitoramento.
- Tráfego sensível deve utilizar criptografia em trânsito sempre que tecnicamente possível.
- Redes e ambientes de produção, desenvolvimento e testes devem ser segregados de forma compatível com o risco.
- Wi-Fi público não confiável não deve ser utilizado para administração de ambientes críticos sem proteção adicional apropriada.

9. Desenvolvimento seguro e mudanças

- Mudanças em produção devem ser rastreáveis, revisadas e aprovadas de acordo com o impacto.
- Código-fonte deve permanecer em repositório controlado, com autenticação e histórico de alterações.
- Segredos e credenciais não devem ser incluídos no código ou em artefatos de build.
- Dependências e bibliotecas devem ser atualizadas considerando vulnerabilidades conhecidas.

- Funcionalidades que tratem dados sensíveis devem considerar validação de entrada, autorização, proteção contra abuso e registro de eventos.
- Ambientes de teste não devem utilizar dados pessoais reais sem necessidade e controles adequados.

10. Proteção de dados, criptografia e privacidade

- Coletar e manter apenas os dados necessários para finalidades legítimas e informadas.
- Aplicar controles de acesso e criptografia proporcionais à sensibilidade da informação.
- Evitar envio de dados confidenciais por canais não autorizados.
- Definir prazos de retenção e descarte seguro compatíveis com obrigações legais, contratuais e operacionais.
- Solicitações relacionadas a dados pessoais devem ser encaminhadas ao responsável designado para privacidade.

11. Backup, recuperação e continuidade

- Dados e configurações críticas devem possuir cópias de segurança compatíveis com os objetivos de recuperação do negócio.
- Backups devem ser protegidos contra acesso indevido, alteração e exclusão não autorizada.
- A restauração deve ser testada periodicamente para validar a utilidade das cópias.
- Incidentes que afetem disponibilidade devem seguir procedimentos de continuidade e recuperação.

12. Logs, monitoramento e rastreabilidade

- Eventos relevantes de autenticação, administração, alterações críticas, falhas e acessos sensíveis devem ser registrados quando tecnicamente possível.
- Logs devem possuir acesso restrito e retenção suficiente para suporte a investigação, auditoria e requisitos aplicáveis.
- Alertas de segurança devem ser avaliados e tratados conforme criticidade.
- Não é permitido apagar ou manipular evidências de segurança sem autorização formal.

13. Gestão de vulnerabilidades e atualizações

- Vulnerabilidades identificadas devem ser registradas, classificadas e corrigidas conforme risco e exposição.
- Atualizações críticas de segurança devem receber prioridade.
- Serviços obsoletos, sem suporte ou desnecessários devem ser substituídos, isolados ou removidos.
- Testes de segurança e revisões técnicas devem ser realizados de acordo com o risco dos sistemas.

14. Gestão de fornecedores e terceiros

- Fornecedores com acesso a dados ou sistemas devem ser avaliados conforme criticidade do serviço.
- Contratos e acordos devem incluir requisitos de segurança e confidencialidade quando aplicável.
- Acessos de terceiros devem ser limitados ao período e escopo necessários.
- Incidentes de fornecedores que possam afetar a 2trac devem ser comunicados e acompanhados.

15. Resposta a incidentes

Qualquer suspeita de acesso indevido, vazamento, malware, perda de dispositivo, credencial comprometida, indisponibilidade anormal ou atividade suspeita deve ser tratada como evento de segurança.

1. Identificar e registrar o evento.
2. Conter o impacto e preservar evidências.
3. Avaliar criticidade, sistemas e dados afetados.
4. Erradicar a causa e recuperar os serviços de forma controlada.
5. Comunicar partes internas e externas quando exigido.
6. Documentar lições aprendidas e implementar ações corretivas.

16. Controles operacionais diários

Os seguintes controles constituem uma linha de base para a operação diária. A frequência pode ser ajustada conforme criticidade, automação e risco.

Momento	Verificação mínima	Evidência esperada
Início do dia	Revisar alertas críticos, falhas de backup, indisponibilidades, acessos suspeitos e jobs essenciais.	Painel, alerta, ticket ou registro de monitoramento.
Durante a operação	Usar contas individuais, MFA, menor privilégio, canais autorizados e não expor credenciais.	Logs de acesso e registros de mudança.
Mudanças e deploys	Confirmar revisão, autorização, rollback e ausência de segredos em código/configuração.	Pull request, change log, ticket ou registro equivalente.
Tratamento de dados	Verificar finalidade, necessidade, compartilhamento autorizado e classificação da informação.	Registro do processo, contrato ou controle de acesso.
Fim do dia	Confirmar jobs críticos, backups, alertas pendentes e incidentes em acompanhamento.	Status operacional e tickets atualizados.
Ao identificar incidente	Interromper ações de risco, preservar evidências e acionar o fluxo de resposta.	Registro do incidente e linha do tempo.

17. Treinamento e conscientização

- Colaboradores devem receber orientação periódica sobre phishing, senhas, tratamento de dados, engenharia social e reporte de incidentes.
- Treinamentos devem ser reforçados quando houver mudanças relevantes, incidentes ou identificação de comportamento de risco.

18. Conformidade, exceções e auditoria

- O descumprimento desta política pode resultar em restrição de acesso e medidas administrativas compatíveis com a relação contratual.
- Exceções devem ser justificadas, aprovadas, possuir prazo definido e, quando possível, controles compensatórios.
- A 2trac pode realizar verificações e auditorias para confirmar a aplicação dos controles definidos.

19. Revisão e atualização da política

Esta política deve ser revisada no mínimo uma vez por ano e sempre que ocorrer qualquer evento que possa alterar significativamente o perfil de risco, incluindo mudanças relevantes de tecnologia, arquitetura, processos, legislação, contratos, requisitos de parceiros, incidentes graves ou resultados de auditoria. Além da revisão formal anual, a efetividade dos controles operacionais críticos deve ser verificada periodicamente, preferencialmente em ciclos trimestrais, com registro das ações corretivas necessárias.

- A revisão deve avaliar a eficácia dos controles e a necessidade de incluir, remover ou reforçar medidas.
- Toda alteração deve gerar nova versão, data de vigência e registro resumido da mudança.

- A versão vigente deve estar acessível às pessoas que necessitam consultá-la.

20. Referências de boas práticas

Esta política foi estruturada com base em práticas amplamente reconhecidas de gestão de segurança da informação, incluindo princípios de gestão de riscos, controles de segurança, proteção de dados, desenvolvimento seguro, resposta a incidentes e continuidade. A adoção deste documento não representa, por si só, certificação em qualquer norma.

- ISO/IEC 27001 - Sistemas de Gestão de Segurança da Informação.
- ISO/IEC 27002 - Controles de Segurança da Informação.
- NIST Cybersecurity Framework - práticas de governança, identificação, proteção, detecção, resposta e recuperação.
- Lei Geral de Proteção de Dados Pessoais (LGPD), quando aplicável ao tratamento de dados pessoais.

21. Controle de versões e aprovação

Versão	Data	Descrição	Responsável
1.0	15/08/2026	Emissão inicial da Política de Segurança da Informação.	Direção / Segurança da Informação
1.1	15/08/2026	Inclusão de políticas específicas de rede, endpoints, acesso, classificação e criptografia, resposta a incidentes, vulnerabilidades, notificação de violações e proteção de dados pessoais.	Direção / Segurança da Informação

Elaborado por	_____
Aprovado por	_____
Data de aprovação	____ / ____ / _____

ANEXO A - POLÍTICAS E PROCEDIMENTOS ESPECÍFICOS DE SEGURANÇA

Este anexo complementa a Política de Segurança da Informação da 2trac Tecnologia LTDA e estabelece controles específicos que devem ser aplicados às operações diárias, sistemas corporativos, ambientes em nuvem, integrações, terminais, redes e tratamento de dados pessoais. Os responsáveis técnicos devem manter evidências de implementação, monitoramento e revisão.

A.1 Política de segregação de rede e proteção contra ameaças

A 2trac deve segmentar redes e ambientes de acordo com sua finalidade, criticidade e nível de confiança, evitando que usuários, dispositivos ou serviços tenham conectividade lateral desnecessária. A arquitetura deve reduzir a superfície de ataque e limitar o impacto de comprometimentos.

- Separar, sempre que aplicável, ambientes de produção, homologação/desenvolvimento, administração, bancos de dados, serviços expostos à Internet e redes de usuários.
- Aplicar regras de firewall e listas de controle de acesso com política de negação por padrão para fluxos não necessários.
- Restringir portas, protocolos e serviços ao mínimo necessário e documentar exceções.
- Usar mecanismos de detecção e prevenção de ameaças, como logs de firewall, IDS/IPS, WAF, proteção de endpoint, monitoramento de tráfego e alertas de comportamento anômalo, conforme o risco.
- Monitorar tentativas de acesso indevido, varreduras, autenticações suspeitas, volume anômalo, malware e alterações não autorizadas.
- Revisar regras de rede e acessos administrativos periodicamente e sempre após alterações relevantes de infraestrutura.
- Manter acesso administrativo remoto protegido por autenticação forte, criptografia e, quando aplicável, VPN ou mecanismo equivalente.

Revisão mínima: trimestral para regras críticas de conectividade e imediatamente após incidentes ou mudanças relevantes de arquitetura.

A.2 Política de proteção de terminais: antivírus, firewall e ferramentas de segurança

Computadores, notebooks, servidores e demais terminais corporativos devem possuir configuração mínima de segurança compatível com sua função e exposição.

- Utilizar software antivírus/antimalware ou solução EDR equivalente, mantido ativo e atualizado, quando tecnicamente aplicável.
- Manter firewall local habilitado nos terminais e servidores, permitindo somente comunicações necessárias.
- Habilitar atualização automática ou processo controlado de aplicação de correções de segurança do sistema operacional, navegadores e aplicações.
- Ativar criptografia de disco nos equipamentos que armazenem dados corporativos ou confidenciais, quando suportada.
- Restringir privilégios administrativos locais; o uso de conta administrativa deve ocorrer apenas quando necessário.
- Bloquear ou controlar execução de softwares não autorizados e remover aplicações obsoletas ou sem suporte.
- Centralizar, quando possível, inventário de ativos, status de proteção, alertas e eventos relevantes de segurança.
- Isolar da rede equipamentos identificados como comprometidos até análise e liberação.

A.3 Política de segurança básica das operações diárias

- Bloqueio de tela: estações devem bloquear automaticamente após período de inatividade compatível com o risco, recomendado em até 10 minutos, e exigir nova autenticação para desbloqueio.
- Complexidade de senha: senhas devem possuir comprimento adequado, preferencialmente 12 caracteres ou mais para contas corporativas, combinando robustez, unicidade e proibição de reutilização entre serviços.
- Gerenciador de senhas: credenciais corporativas devem ser armazenadas em solução autorizada, quando disponível; é proibido armazenar senhas em texto puro ou em locais não protegidos.

- Mesa limpa: documentos confidenciais, mídias removíveis, anotações com credenciais ou dados pessoais não devem permanecer expostos quando o usuário se afastar do posto de trabalho ou ao fim do expediente.
- Tela limpa: informações confidenciais não devem permanecer visíveis em telas desatendidas, reuniões públicas, compartilhamentos de tela ou ambientes sem controle.
- Autenticação multifator (MFA): deve ser obrigatória para acessos administrativos, sistemas críticos, e-mail corporativo, nuvem, repositórios de código, painéis de parceiros e demais serviços que suportem o recurso.
- Uso de dispositivos: não utilizar dispositivos pessoais ou mídias externas para armazenar informações restritas sem autorização e controles adequados.
- Reporte imediato: qualquer comportamento suspeito, phishing, perda de dispositivo ou falha de controle deve ser comunicado ao canal corporativo de segurança.

A.4 Política de controle de acesso e privilégio mínimo para dados pessoais

O acesso a dados pessoais e a sistemas que os processem deve ser concedido exclusivamente com base na necessidade de negócio, função exercida e princípio do privilégio mínimo.

- Toda conta deve ser individual e rastreável, exceto contas técnicas formalmente controladas.
- A concessão de acesso deve ser autorizada pelo responsável pelo sistema ou processo e limitada ao escopo necessário.
- Perfis administrativos devem ser separados das contas de uso cotidiano sempre que possível.
- Acessos a dados pessoais sensíveis ou grandes volumes de dados devem receber controles reforçados e monitoramento compatível com o risco.
- Permissões devem ser revisadas periodicamente, no mínimo a cada seis meses, e imediatamente em mudanças de função, desligamentos ou encerramento de contrato.
- Contas inativas, órfãs ou desnecessárias devem ser desabilitadas sem atraso.
- Exportações, consultas massivas e ações administrativas relevantes devem ser registradas quando tecnicamente possível.

A.5 Política de classificação de dados e criptografia

A 2trac adota classificação de dados em níveis Pública, Interna, Confidencial e Restrita. O tratamento, armazenamento, compartilhamento e descarte devem respeitar a classificação atribuída e a necessidade de negócio.

- Dados Confidenciais e Restritos devem utilizar criptografia em trânsito por protocolos seguros, como TLS/HTTPS, SSH, VPN ou equivalentes, quando aplicável.
- Dados Confidenciais e Restritos armazenados em bancos, volumes, backups ou dispositivos devem utilizar criptografia em repouso quando tecnicamente suportada e proporcional ao risco.
- Chaves criptográficas, tokens, certificados e segredos devem ser protegidos em cofre de segredos ou mecanismo equivalente, com acesso restrito.
- É proibida a transmissão de dados confidenciais por canais não autorizados ou sem proteção adequada.
- Backups com dados confidenciais devem herdar controles de criptografia e acesso compatíveis com os dados de origem.
- A classificação deve ser revista quando a finalidade, conteúdo, risco ou obrigação contratual/regulatória mudar.

A.6 Política de resposta a incidentes, responsabilidades e comunicação

A resposta a incidentes deve seguir um processo formal com papéis definidos, registro de evidências, comunicação adequada e coordenação entre tecnologia, segurança, direção, jurídico/privacidade e áreas de negócio, conforme a natureza do evento.

Função	Responsabilidade mínima
Direção	Aprovar decisões críticas, mobilizar recursos e autorizar comunicações externas relevantes.
Segurança da Informação	Coordenar triagem, contenção, investigação, preservação de evidências, análise de impacto e lições aprendidas.

Tecnologia/Operações	Executar contenção técnica, correções, recuperação, restauração e monitoramento.
Privacidade/Jurídico	Avaliar impacto sobre dados pessoais, obrigações contratuais e necessidade de notificações aplicáveis.
Responsável pelo negócio/cliente	Apoiar avaliação do impacto operacional e comunicação com clientes, parceiros ou vendedores.

- Canais internos de reporte: e-mail corporativo designado para segurança, sistema de tickets/incidentes e canal de plantão definido pela Direção.
- Eventos críticos devem ser escalados imediatamente aos responsáveis de Segurança e Direção.
- Toda ocorrência deve possuir registro de data/hora, fonte, ativos afetados, ações executadas, evidências e responsáveis.
- Comunicações externas devem ser factuais, aprovadas e limitadas às informações necessárias.

A.7 Procedimento de gerenciamento de vulnerabilidades e ameaças

Vulnerabilidades técnicas e ameaças identificadas devem ser tratadas por processo contínuo de descoberta, análise, priorização, correção, validação e acompanhamento.

1. Identificar vulnerabilidades por atualizações de fornecedores, scanners, testes técnicos, monitoramento, auditorias, alertas de segurança e relatos internos/externos.
2. Registrar cada achado com ativo afetado, descrição, evidência, severidade, responsável e prazo de tratamento.
3. Priorizar considerando criticidade do ativo, exposição à Internet, existência de exploração conhecida, impacto sobre dados e disponibilidade de correção.
4. Aplicar correções, atualizações, mitigação, isolamento ou controle compensatório dentro de prazo proporcional ao risco.
5. Validar a correção por nova verificação ou teste e registrar a evidência de encerramento.
6. Aceites de risco devem ser formais, possuir justificativa, prazo de validade, responsável e controles compensatórios.
7. Ameaças ativas ou exploração confirmada devem ser tratadas como incidente de segurança e seguir o processo de resposta a incidentes.

Parâmetro operacional sugerido: vulnerabilidades críticas devem receber tratamento prioritário e acompanhamento até mitigação; prazos internos podem ser definidos conforme exposição e risco do ativo.

A.8 Processo de notificação de violações de dados suspeitas ou identificadas

Quando houver suspeita ou confirmação de comprometimento de dados de clientes, vendedores, parceiros ou usuários, a 2trac deve avaliar rapidamente o evento e determinar a necessidade de comunicação às partes afetadas e demais destinatários aplicáveis.

1. Registrar a suspeita imediatamente e acionar Segurança da Informação e Privacidade/Jurídico.
2. Confirmar, na medida do possível, os dados envolvidos, categorias de titulares, volume aproximado, sistemas afetados, período e causa provável.
3. Classificar o risco e avaliar possibilidade de uso indevido, fraude, exposição ou impacto aos titulares e vendedores.
4. Notificar vendedores, clientes ou parceiros afetados por canal corporativo oficial quando o evento puder impactar seus dados, operações ou obrigações.
5. A comunicação deve informar, conforme disponível e apropriado: natureza do incidente, dados possivelmente afetados, período, medidas tomadas, recomendações de proteção e canal de contato para acompanhamento.
6. As notificações devem ocorrer sem atraso indevido, respeitando requisitos legais, regulatórios e contratuais aplicáveis.
7. Manter registro de decisões, destinatários, conteúdo e data/hora das notificações realizadas.

A.9 Política interna de proteção de dados pessoais

A 2trac deve manter política interna de proteção de dados pessoais alinhada às atividades efetivamente realizadas, princípios de privacidade, obrigações contratuais e legislação aplicável. A política deve ser revisada regularmente e sempre que houver mudança relevante no tratamento de dados.

- Coletar e tratar somente dados necessários para finalidade legítima, específica e informada.
- Manter inventário ou registro das principais atividades de tratamento, sistemas envolvidos e responsáveis.
- Aplicar controles de acesso, retenção, descarte, criptografia e rastreabilidade proporcionais ao risco.
- Restringir compartilhamento de dados pessoais a destinatários autorizados e finalidade compatível.
- Avaliar fornecedores que processem dados pessoais em nome da 2trac e estabelecer obrigações adequadas de confidencialidade e segurança.
- Atender solicitações de titulares e obrigações de privacidade por processo definido e rastreável.
- Revisar a política ao menos anualmente e após mudanças legais, contratuais, tecnológicas, incidentes ou inclusão de novas categorias de dados.

A.10 Evidências, auditoria e revisão dos controles

- Os responsáveis pelos controles devem manter evidências proporcionais à criticidade, como configurações, capturas, relatórios, logs, tickets, registros de aprovação e resultados de testes.
- Controles críticos de acesso, rede, endpoints, backup, vulnerabilidades e incidentes devem ser verificados periodicamente.
- Falhas identificadas devem originar plano de ação com responsável e prazo.
- Este anexo deve ser revisto junto com a Política de Segurança da Informação e atualizado sempre que houver alteração relevante no ambiente, nos riscos ou nos requisitos de parceiros.

Fim do Anexo A - versão 1.1